

NMAP

The ultimate guide.

Every flag that matters.

WHAT'S INSIDE

- Target Specification
- Host Discovery
- Port Specification
- TCP Scan Techniques
- UDP Scanning
- Service & OS Detection
- Timing & Performance
- NSE Basics
- Web Recon
- Internal Recon
- Vulnerability Scanning
- Firewall / IDS Evasion
- Output & Resume
- Common Recipes

FOR

Pentesters · Red teamers · Blue teamers
CTF players · Self-learners · Beginners

→ swipe to start





```
$ nmap -iL hosts.txt --exclude 192.168.1.1
Starting Nmap 7.94 ( https://nmap.org )
Nmap scan report for 192.168.1.5
Host is up (0.0012s latency)
Nmap scan report for 192.168.1.10
Host is up (0.0024s latency)
Nmap done: 24 IPs (8 hosts up) in 4.83s
```

```
$ nmap 192.168.0.0/16      # whole subnet
$ nmap 192.168.1.1-254   # range syntax
```

FLAGS

<target>	Single IP, hostname, or domain
<CIDR>	Entire subnet (e.g. /24, /16)
a-b	IP range with dash notation
-iL <file>	Read target list from a file
--exclude	Skip specified targets
--excludefile	Skip targets listed in a file

OVERVIEW

Every Nmap command starts with what to scan. Mix single IPs, ranges, CIDR blocks, hostnames and file inputs in the same command. Always use `--exclude` on shared infrastructure to keep out-of-scope assets safe.





```
$ nmap -sn 192.168.1.0/24
Nmap scan report for 192.168.1.1
Host is up (0.0008s latency)
Nmap scan report for 192.168.1.10
Host is up (0.0014s latency)
Nmap done: 256 IPs (8 hosts up) in 2.5s

$ nmap -PE -PS80,443 -PA80 target.com
$ nmap -PR 192.168.1.0/24      # ARP, LAN only
$ nmap -Pn target.com         # skip discovery
```

FLAGS

-sn	Ping scan, no port scan
-PE	ICMP echo request
-PS <ports>	TCP SYN ping
-PA <ports>	TCP ACK ping
-PR	ARP ping (LAN only, fastest)
-Pn	Skip discovery, treat all as up
-n	No DNS resolution

OVERVIEW

Find live hosts before scanning ports. ICMP is often blocked at the perimeter, so combine TCP SYN and ACK pings on common ports. On a local network ARP ping is the fastest and most reliable method.



```
$ nmap -p 80,443,8080 target.com
```

PORT	STATE	SERVICE
80/tcp	open	http
443/tcp	open	https
8080/tcp	closed	http-proxy

```
$ nmap -p- target.com # all 65535 ports
```

```
$ nmap --top-ports 1000 target.com # top 1000
```

```
$ nmap -F target.com # fast: top 100
```

```
$ nmap -p T:80,U:53 target.com # TCP + UDP
```

FLAGS

- | | |
|---------------------------|--------------------------------|
| -p <ports> | Specify ports (e.g. 22,80,443) |
| -p- | All 65535 ports |
| -F | Fast mode (top 100 ports) |
| --top-ports N | Top N most common ports |
| -p T:<ports> | TCP ports only |
| -p U:<ports> | UDP ports only |
| -r | Scan sequentially, no random |

OVERVIEW

Default scans hit only the top 1000 TCP ports. Real engagements need -p- for full coverage. Common ports (22, 80, 443, 3389, 445) should always be explicitly listed even on fast scans to ensure no gaps.



```
$ sudo nmap -sS -p 80,443 target.com
```

PORT	STATE	SERVICE
80/tcp	open	http
443/tcp	open	https

```
$ nmap -sT target.com # connect, no root
```

```
$ sudo nmap -sA -p 1-1000 target.com # firewall map
```

```
$ sudo nmap -sF target.com # FIN, stealth
```

```
$ sudo nmap -sN target.com # NULL scan
```

```
$ sudo nmap -sX target.com # XMAS scan
```

FLAGS

- sS** TCP SYN (half-open, stealth, root)
- sT** TCP connect (no root needed)
- sA** TCP ACK (maps firewall rules)
- sF** TCP FIN (bypasses some firewalls)
- sN** TCP NULL (no flags set)
- sX** TCP XMAS (FIN + PSH + URG)
- scanflags** Custom TCP flag combination

OVERVIEW

SYN scan is the default and best for most cases: fast, stealthy, no full handshake. Use Connect when you cannot run as root. ACK scan maps firewall rules. FIN, NULL and XMAS bypass stateless filters.





```
$ sudo nmap -sU --top-ports 20 target.com
PORT      STATE      SERVICE
53/udp    open       domain
123/udp   open       ntp
161/udp   open|filtered snmp
500/udp   open       isakmp

$ sudo nmap -sUV -p 53,161 target.com
$ sudo nmap -sU --top-ports 100 -T4 target.com
```

FLAGS

-sU	UDP scan (slow, needs root)
-sUV	UDP + service version detection
--top-ports 100	Fastest UDP coverage strategy
--max-retries 1	Speed up UDP scans
-T4	Faster timing for UDP
-p 53,161,500	Common UDP services

OVERVIEW

DNS, SNMP, NTP, IKE, DHCP, NetBIOS all run on UDP. Skipping UDP misses half the attack surface. UDP scans are slow because of ICMP rate limits, so always restrict to top ports or specific services.





```
$ sudo nmap -sV -O target.com
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu
80/tcp    open  http     nginx 1.18.0
443/tcp   open  ssl/http nginx 1.18.0
OS: Linux 4.15 - 5.6 (95%)

$ sudo nmap -A target.com           # all-in-one
$ nmap -sV --version-intensity 9 target.com
$ sudo nmap -O --osscan-guess target.com
```

FLAGS

-sV	Service / version detection
-O	OS detection (requires root)
-A	Aggressive: -sV -O -sC traceroute
--version-light	Intensity 2 (faster, less noise)
--version-all	Intensity 9 (most thorough)
--osscan-guess	Guess OS even when uncertain

OVERVIEW

Version detection turns port numbers into actionable intel. -A is the shortcut every pentester uses for initial recon. OS detection needs at least one open and one closed TCP port to fingerprint.



```
$ nmap --max-retries 2 target.com # fewer retries
```

-T0 / -T1	Paranoid / Sneaky (IDS evasion)
-T2	Polite (less bandwidth)
-T3	Normal (default)
-T4	Aggressive (best for most cases)
-T5	Insane (accuracy may suffer)
--min-rate N	Minimum packets per second
--host-timeout	Give up on slow hosts

T4 is the sweet spot for most engagements: fast enough for productivity, accurate enough for results. T0 to T2 are for IDS evasion when stealth matters more than time spent on the scan.



```
$ nmap --script "http-*" -p 80,443 target.com
80/tcp open http
| http-title: Welcome
| http-headers: Server: nginx/1.18.0
| http-methods: GET HEAD POST OPTIONS
| http-enum: /admin/ /backup/ /robots.txt

$ nmap --script ssl-enum-ciphers -p 443 target.com
$ nmap --script http-vuln-cve2017-5638 target.com
$ nmap --script "ssl-*" -p 443 target.com
```

FLAGS

http-title	Page title extraction
http-headers	Response headers + Server banner
http-methods	Allowed HTTP methods (PUT, DELETE)
http-enum	Common directories and files
http-robots.txt	Disallowed paths from robots.txt
http-vuln-*	Known web vulnerability CVEs
ssl-enum-ciphers	Cipher suites and TLS versions
ssl-heartbleed	CVE-2014-0160 (Heartbleed)

OVERVIEW

NSE web scripts give a complete first-pass recon: title, headers, methods, directories and CVEs in one command. Pair http-* with ssl-* to fingerprint both the application and the TLS stack.





```
$ nmap --script "smb-*" -p 445 192.168.1.10
445/tcp open microsoft-ds
| smb-os-discovery: Windows Server 2019
| smb-enum-shares: SYSVOL ADMIN$ NETLOGON
| smb-enum-users: jsmith admin guest
| smb-vuln-ms17-010: VULNERABLE (EternalBlue)

$ nmap --script "ldap-*" -p 389 dc.lab.local
$ nmap --script ssh-auth-methods -p 22 target.com
$ nmap --script rdp-enum-encryption -p 3389 target.com
```

FLAGS

smb-os-discovery	Windows version + domain info
smb-enum-shares	SMB shares including hidden
smb-enum-users	Domain user enumeration
smb-vuln-ms17-010	EternalBlue (MS17-010) check
ldap-search	LDAP queries (AD enumeration)
ssh-auth-methods	Supported SSH auth methods
rdp-enum-encryption	RDP encryption levels

OVERVIEW

Internal pentests live or die by SMB and LDAP enumeration. smb-* scripts pull OS, shares, users and check for the big vulns. Always run these before reaching for BloodHound.





```
$ nmap --script vuln -p 22,80,443,445 target.com
80/tcp    open  http
| http-csrf: Possible CSRFs in form fields
| http-stored-xss: Reflected XSS detected
445/tcp    open  microsoft-ds
| smb-vuln-ms17-010: VULNERABLE
|   IDs: CVE-2017-0143

$ nmap --script vulners -sV target.com
$ nmap --script ssl-heartbleed -p 443 target.com
```

FLAGS

--script vuln	All vulnerability scripts at once
--script vulners	Match CVEs by version (needs -sV)
smb-vuln-ms17-010	EternalBlue check
smb-vuln-ms08-067	Conficker / older Windows
ssl-heartbleed	CVE-2014-0160 (Heartbleed)
ssl-ccs-injection	CVE-2014-0224
http-shellshock	CVE-2014-6271 (Bash)

OVERVIEW

The vuln category auto-checks for known CVEs across detected services. The vulners script is the most useful: it maps version strings to CVE databases. Always validate manually.





```
$ sudo nmap -f -D 10.0.0.5,10.0.0.10,ME target.com
Sending fragmented packets with 3 decoys
22/tcp    open    ssh
443/tcp   open    https

$ sudo nmap --mtu 16 target.com           # custom MTU
$ sudo nmap -D RND:10 target.com          # random decoys
$ sudo nmap -S 192.168.1.99 target.com    # spoof source
$ sudo nmap --source-port 53 target.com   # as DNS
$ sudo nmap --data-length 200 target.com  # pad
```

FLAGS

-f	Fragment packets (8 bytes)
--mtu N	Custom MTU, must be multiple of 8
-D <decoys>	Use decoy IPs (ME = your real IP)
-D RND:N	N random decoy IPs
-S <ip>	Spoof source IP address
--source-port	Use fixed source port (53, 88)
--data-length	Pad packets with random data
--badsum	Bad checksums (detect IDS/IPS)

OVERVIEW

Real-world evasion uses 2-3 techniques together, not all at once. Fragmenting + decoys + slow timing (-T2) bypasses most signature-based IDS. Source port 53 slips through stateless rules.





```
$ nmap -oA scan_results target.com
Starting Nmap 7.94
22/tcp open  ssh
Nmap done

$ ls scan_results.*
scan_results.gnmap  scan_results.nmap  scan_results.xml

$ nmap -v -oN scan.txt -p- target.com
$ nmap --resume scan_results.gnmap # continue
$ nmap -oG - target.com | grep "open"
```

FLAGS

-oN <file>	Normal text output
-oX <file>	XML output (parseable)
-oG <file>	Grep-friendly output
-oA <prefix>	All three formats at once
-v / -vv	Increase verbosity level
--reason	Why a port is in that state
--open	Show only open ports
--resume	Resume an interrupted scan

OVERVIEW

Always use -oA for engagements. XML feeds reporting tools, grep output is perfect for pipelines. --resume saves hours when long internal scans get interrupted mid-run.





```
# Deep enumeration: scripts + versions + all ports
$ nmap -sC -sV -p- -T4 --min-rate 1000 -oA full
    target.com

# Quick recon: skip ping, top 1000 TCP
$ nmap -Pn -sS --top-ports 1000 -T4 target.com

# UDP coverage of top 100 services
$ sudo nmap -sU --top-ports 100 -T4 target.com

# Vuln baseline across common services
$ nmap --script vuln -sV -p 21,22,80,443,445 target.com
```

FLAGS

-sC -sV -p-	Full enum: scripts + versions + all ports
-A	Aggressive shortcut (-sC -sV -O traceroute)
-Pn --top-ports N	Quick external recon
-T4 --min-rate N	Productive timing combo
-oA <prefix>	Save all 3 output formats
--script vuln -sV	Vuln baseline scan

OVERVIEW

These are the commands every pentester actually runs. Memorize the deep enum and quick recon patterns and you cover 90% of engagements. Always pair scans with -oA for reporting.



THANKS FOR READING

Save this guide.



@kerem.tech



@keraattin



@keraattin



@keraattin
Kerem Tech

REMEMBER

Trust nothing. Verify everything.



@kerem.tech

@keraattin

